

MF0487_3 - AUDITORIA DE SEGURIDAD INFORMATICA
LABORATORIO 8 — LABORATORIO FINAL
Informe de Auditoria de Seguridad

Sistema auditado: Metasploitable 2

Entorno: Kali Linux Purple + Metasploitable 2

Normativa: ISO 27007:2011 - ENS RD 311/2022 - LOPDGDD LO 3/2018 - RGPD

Integracion de: LAB-01 Reconocimiento | LAB-02 OpenVAS | LAB-03 Wireshark

LAB-04 OWASP | LAB-05 Firewall | LAB-06 Contraseñas | LAB-07 MAGERIT

Duracion estimada: 6 horas - Nivel: Avanzado - Prerrequisitos: LAB-01 al LAB-07

CLASIFICACION: CONFIDENCIAL — Documento de uso interno del laboratorio. No difundir fuera del entorno de formacion.

Este es el laboratorio de sintesis del curso. Integra todos los resultados anteriores en un Informe de Auditoria profesional conforme a ISO 27007:2011.

0. FICHA TECNICA DEL LABORATORIO

Codigo	LAB-08	UD	UD6
Titulo	Informe de Auditoria de Seguridad Final — Metasploitable 2	Duracion	6 h
Normativa	ISO 27007:2011 - ENS RD 311/2022 - LOPDGDD LO 3/2018 - RGPD - ISO 27001:2022 - CCN-STIC 802/803	Nivel	Avanzado
Fuentes	Resultados de LAB-01 a LAB-07 (todos los laboratorios anteriores)	Prereq.	LAB-01 al 07
Objetivo	<i>Redactar el Informe de Auditoria de Seguridad final integrado conforme a ISO 27007:2011 y la estructura de informes del ENS. Consolidar todos los hallazgos de los laboratorios anteriores en un unico documento profesional con resumen ejecutivo, analisis normativo, declaracion de aplicabilidad, plan de accion y registro de firmas.</i>		
Producto final	<i>Informe de Auditoria de Seguridad (IAS) completo: documento unico que integra evidencias tecnicas (LAB-01 a 06) y el analisis de riesgos (LAB-07) en el formato exigido por ISO 27007 para informes de auditoria de un SGSI.</i>		

1. MARCO NORMATIVO DE LA AUDITORIA DE SEGURIDAD

Un Informe de Auditoria de Seguridad profesional debe estar anclado en un marco normativo claro que defina el proceso de auditoria, los criterios de evaluacion y las obligaciones de comunicacion de resultados. Este laboratorio aplica tres marcos complementarios:

1.1 ISO/IEC 27007:2011 — Guidelines for Information Security Management Systems Auditing

ISO 27007 es la norma internacional que define las directrices para realizar auditorias de Sistemas de Gestion de Seguridad de la Informacion (SGSI). Es el complemento de auditoria de ISO 27001 y establece:

- * El proceso de auditoria en tres fases: iniciacion, ejecucion y reporte.
- * Los criterios de auditoria: las politicas, procedimientos, controles y requisitos normativos que se evaluan.
- * Las evidencias de auditoria: registros, declaraciones de hechos y otra informacion verificable que es relevante para los criterios de auditoria y verificable.
- * Las conclusiones de auditoria: resultado de la evaluacion de las evidencias de auditoria recopiladas frente a los criterios de auditoria.
- * Los hallazgos de auditoria: resultado de evaluar las evidencias de auditoria recopiladas frente a los criterios. Incluyen conformidades, no conformidades y observaciones.
- * El informe de auditoria: documento que presenta los resultados de la auditoria de forma estructurada, incluyendo el plan de auditoria, el resumen de los hallazgos y las conclusiones.

ISO 27007: ISO 27007 distingue entre NO CONFORMIDAD MAYOR (incumplimiento que afecta a la eficacia del SGSI), NO CONFORMIDAD MENOR (incumplimiento que no compromete la eficacia global) y OBSERVACION (area de mejora sin incumplimiento formal). El auditor debe clasificar cada hallazgo en una de estas tres categorias.

1.2 ENS — Esquema Nacional de Seguridad (RD 311/2022)

El ENS es el marco de referencia obligatorio para la seguridad de los sistemas de informacion de las Administraciones Publicas espanolas y sus proveedores. Para los efectos de este informe, el ENS define:

- * Categorías del sistema: BASICA, MEDIA o ALTA, en funcion del impacto de un incidente sobre las dimensiones D, I, C, A y T.
- * Medidas de seguridad obligatorias: el Anexo II del ENS define las medidas de seguridad exigibles segun la categoria del sistema. Las medidas se agrupan en: Marco Organizativo (org), Marco Operacional (op) y Medidas de Proteccion (mp).
- * Auditoria del ENS (art. 31): los sistemas de categoria MEDIA y ALTA deben someterse a una auditoria de seguridad al menos cada dos anos. La auditoria debe realizarse por personal cualificado e independiente.
- * Informe de auditoria ENS: debe incluir los sistemas auditados, los controles verificados, los resultados (conforme / no conforme), las deficiencias encontradas y el plan de correccion.

ENS: El art. 31.3 del ENS establece que el informe de auditoria tendra caracter confidencial y debera estar a disposicion del responsable del sistema, del responsable de seguridad y del CCN-CERT. En el sector privado que trata con la Administracion, aplica el mismo requisito a los sistemas que manejan datos de las AA.PP.

1.3 LOPDGDD y RGPD — Perspectiva de proteccion de datos

Cuando el sistema auditado trata datos personales, el informe de auditoria debe incluir una evaluacion especifica de las medidas de seguridad del tratamiento. La LOPDGDD y el RGPD establecen:

- * RGPD art. 32: el responsable del tratamiento debe implementar medidas tecnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo. El informe de auditoria es evidencia del cumplimiento de este articulo.

- * RGPD art. 33: en caso de brecha de seguridad que afecte a datos personales, el responsable debe notificar a la AEPD en 72 horas. El informe de auditoria puede constituir la evidencia de la brecha.
- * RGPD art. 35 (DPIA/EIPD): cuando el tratamiento entra alto riesgo, el responsable debe realizar una Evaluacion de Impacto en la Proteccion de Datos antes de iniciar el tratamiento. La auditoria de seguridad puede ser el instrumento de revision periodica de la DPIA.
- * LOPDGDD art. 28: el delegado de proteccion de datos (DPO) debe supervisar el cumplimiento del RGPD, incluyendo las medidas de seguridad. El informe de auditoria debe compartirse con el DPO.
- * LOPDGDD Disposicion adicional primera: para AA.PP., las medidas de seguridad del ENS son el marco de referencia para el cumplimiento del art. 32 RGPD.

LOPDGDD: La LOPDGDD art. 5 y el RGPD art. 5.1.f establecen el principio de 'integridad y confidencialidad': los datos personales se trataran de manera que se garantice su seguridad. Un informe de auditoria que identifique deficiencias graves en la seguridad de un sistema que trata datos personales tiene implicaciones legales directas para el responsable del tratamiento.

1.4 Estructura del proceso de auditoria segun ISO 27007

Fase ISO 27007	Descripcion	Actividades principales	Producto del LAB correspondiente
1. Iniciacion	Establecer el alcance, objetivos y criterios de la auditoria	Definir alcance, seleccionar equipo auditor, revisar documentacion previa	Plan de auditoria (este documento, seccion 2)
2. Preparacion	Revisar la documentacion existente y preparar el programa de auditoria	Revision de politicas, procedimientos, resultados de auditorias anteriores	Revision documental (seccion 3)
3. Ejecucion	Realizar las pruebas tecnicas y recopilar evidencias	LAB-01 a LAB-06: reconocimiento, vulnerabilidades, protocolos, web, firewall, contraseñas	Evidencias tecnicas (seccion 4)
4. Informe	Documentar los hallazgos, conclusiones y recomendaciones	Consolidar hallazgos, clasificar NC, redactar informe	Informe final (secciones 5-9 de este documento)
5. Cierre	Realizar el seguimiento de las acciones correctoras	Verificar implementacion del Plan de Accion	Plan de seguimiento (seccion 9)

2. PLAN DE AUDITORIA (SEGUN ISO 27007 SEC. 6.3)

El plan de auditoria es el documento que describe los objetivos, el alcance, los criterios y el programa de la auditoria. Se elabora antes de iniciar las pruebas tecnicas y debe ser aprobado por el responsable del sistema auditado.

2.1 Identificacion de la auditoria

Campo	Valor
Identificador de auditoria	AUD-2025-META-01
Tipo de auditoria	Auditoria tecnica de seguridad (penetration testing + revision de configuracion)
Sistema auditado	Metasploitable 2 — Servidor Linux con servicios de red y aplicaciones web vulnerables
IP del sistema auditado	<IP_META> (asignada en el entorno de laboratorio)
Organizacion cliente	Entorno de laboratorio MF0487_3
Equipo auditor	Alumno: _____ Instructor: _____
Fecha de inicio	_____
Fecha de fin	_____
Criterios de auditoria	ENS RD 311/2022 Anexo II - ISO 27001:2022 Annex A - OWASP WSTG v4.2 - MAGERIT v3
Clasificacion del informe	CONFIDENCIAL
Distribucion	Alumno, Instructor, Coordinador del curso
Version del documento	1.0

2.2 Alcance de la auditoria

El alcance define con precision que sistemas, servicios y controles estan incluidos en la auditoria y cuales estan expresamente excluidos.

Elemento	Incluido en alcance	Justificacion
Servidor Metasploitable 2 (HW-01, SW-01)	SI	Activo principal del laboratorio
Servicios de red: FTP, SSH, Telnet, HTTP, MySQL, SMB	SI	Servicios activos verificados en LAB-01
Aplicaciones web: DVWA, Mutillidae, phpMyAdmin, Tomcat	SI	Auditados en LAB-04
Politica de firewall (iptables)	SI	Auditada en LAB-05
Politica de contraseñas y hashes del sistema	SI	Auditada en LAB-06
Trafico de red (captura Wireshark)	SI	Auditado en LAB-03
Red de aula / infraestructura del centro	NO	Fuera del alcance acordado. Solo el servidor objetivo.
Maquina auditora Kali Linux Purple	NO	Herramienta del auditor, no es el sistema auditado
Servicios en Internet externos	NO	El entorno esta aislado de Internet

2.3 Objetivo de la auditoria

- * Identificar las vulnerabilidades tecnicas del sistema Metasploitable 2 y evaluar su explotabilidad real.
- * Evaluar la conformidad de los controles de seguridad implementados con los requisitos del ENS y la ISO 27001:2022.
- * Identificar los riesgos para los datos que el sistema podria tratar y evaluar el cumplimiento del RGPD art. 32.
- * Proporcionar un Plan de Accion priorizado con medidas tecnicas y organizativas para reducir el riesgo a un nivel aceptable.

2.4 Metodologia aplicada

Metodologia / Estandar	Descripcion	Aplicacion en este laboratorio
ISO/IEC 27007:2011	Estructura del proceso y del informe de auditoria	Marco de referencia para todo el laboratorio
OWASP WSTG v4.2	Pruebas de seguridad de aplicaciones web	LAB-04: SQLi, XSS, CMDi, bypass autenticacion
OSSTMM v3	Metodologia de pruebas de seguridad operacional	LAB-03: analisis de protocolos; LAB-05: firewall
MAGERIT v3	Analisis y gestion de riesgos	LAB-07: identificacion amenazas, calculo riesgo
NIST SP 800-30 Rev.1	Cuantificacion del riesgo (P x I)	LAB-07: probabilidad e impacto 1-5
CVSS v3.1	Puntuacion de vulnerabilidades	LAB-02: todas las vulnerabilidades OpenVAS
CCN-STIC 802	Auditoria de seguridad ENS	Declaracion de aplicabilidad (seccion 8)

3. REVISION DOCUMENTAL (FASE 2 ISO 27007)

La revision documental previa a las pruebas tecnicas es obligatoria en ISO 27007. Permite al auditor entender el contexto del sistema, identificar la documentacion de seguridad existente y detectar gaps documentales antes de iniciar las pruebas.

3.1 Documentacion solicitada y estado

Documento solicitado	Tipo	Estado en Metasploitable 2	Hallazgo documental
Politica de seguridad de la informacion	Organizativo	NO EXISTE	Ausencia de marco de gobierno de seguridad (NC Mayor)
Inventario de activos actualizado	Tecnico	NO EXISTE	El inventario se ha construido en LAB-01 como parte de la auditoria
Analisis de riesgos formal	Metodologico	NO EXISTE	Se ha realizado en LAB-07 como parte de la auditoria (primera vez)
Plan de continuidad del negocio	Operacional	NO EXISTE	Sin BCP ni DRP documentado (NC Mayor)
Politica de contraseñas documentada	Tecnico	NO EXISTE	Sin PAM configurado ni politica escrita (NC Mayor - LAB-06)
Procedimiento de gestion de parches	Tecnico	NO EXISTE	Sistema con versiones obsoletas desde 2008 (NC Mayor - LAB-02)
Registros de auditoria / logs	Tecnico	PARCIAL	Logs basicos del SO. Sin SIEM ni correlacion de eventos
Esquema de red documentado	Tecnico	NO EXISTE	Se ha generado en LAB-01 como parte de la auditoria
Contratos / acuerdos de confidencialidad	Legal	NO APLICA	Entorno de laboratorio
Resultado de auditoria anterior	Historico	NO EXISTE	Primera auditoria del sistema

Conclusion de la revision documental: El sistema carece de practicamente toda la documentacion de seguridad que ISO 27001:2022 y el ENS consideran obligatoria. Esta ausencia documental es, por si sola, un indicador de un nivel de madurez de seguridad muy bajo (nivel 1 en una escala CMM de 1-5).

4. EVIDENCIAS TECNICAS RECOPIADAS (FASE 3 ISO 27007)

Las evidencias tecnicas son los registros verificables obtenidos durante las pruebas tecnicas. Cada evidencia esta numerada, fechada y asociada al laboratorio y herramienta que la genero. Constituyen la base objetiva de cada hallazgo del informe.

4.1 Registro de evidencias

ID Evidencia	Descripcion	Herramienta	Laboratorio	Fichero adjunto	Hallazgos que soporta
E-01	Mapa completo de puertos y servicios (65535 puertos)	Nmap	LAB-01	nmap_syn_full.txt	H-01, H-02, H-03, H-06
E-02	Inventario de activos con valoracion MAGERIT	Nmap + analisis	LAB-01	inventario_activos.xml	Todos los hallazgos
E-03	Escaneo de vulnerabilidades — informe completo OpenVAS	OpenVAS/GVM	LAB-02	openvas_report.xml	H-01, H-02, H-04, H-08
E-04	Captura de credenciales Telnet en texto claro	Wireshark	LAB-03	captura_telnet.pcap	H-06
E-05	Captura de credenciales FTP en texto claro	Wireshark	LAB-03	captura_ftp.pcap	H-07
E-06	Captura trafico ARP (sin proteccion)	Wireshark	LAB-03	captura_arp.pcap	H-10
E-07	Explotacion SQL Injection — extraccion BD usuarios DVWA	Burp Suite / sqlmap	LAB-04	burp_sql_i_repeater.png	H-04, H-09
E-08	Explotacion XSS almacenado — payload persistente	Burp Suite	LAB-04	burp_xss_stored.png	H-05
E-09	Explotacion Command Injection — /etc/passwd	DVWA / Burp	LAB-04	burp_cmdi_passwd.png	H-02
E-10	Ruleset iptables — volcado completo	iptables-save	LAB-05	iptables_actual.txt	H-06, H-07, H-11
E-11	Hashes MD5 extraidos de DVWA	MySQL / SQLi	LAB-04/06	dvwa_md5.txt	H-09
E-12	Crackeo de hashes MD5 DVWA (5/5 crackeados < 30s)	Hashcat	LAB-06	hashcat_md5.txt	H-09
E-13	Ataque Hydra SSH — credenciales msfadmin:msfadmin	Hydra	LAB-06	hydra_ssh.txt	H-08
E-14	Verificacion ausencia pam_faillock y pam_pwquality	SSH / cat /etc/pam.d	LAB-06	pam_config.txt	H-08

E-15	Analisis de riesgos completo — registro de riesgos	MAGERIT v3 + NIST	LAB-07	registro_riesgos.xlsx	Todos los hallazgos
E-16	Declaracion de aplicabilidad ENS — gap analysis	LAB-07 + LAB-08	LAB-07/08	declaracion_aplicabilidad.pdf	Seccion 8

ISO 27007: ISO 27007 exige que toda evidencia de auditoria sea: objetiva (basada en hechos verificables), suficiente (adecuada en cantidad y calidad), relevante (relacion directa con el criterio de auditoria) y fiable (obtenida de fuentes verificadas). Las evidencias generadas en Kali sobre Metasploitable 2 cumplen estos requisitos al ser el resultado de herramientas estandar de auditoria ejecutadas en un entorno controlado.

5. HALLAZGOS DE LA AUDITORIA (CLASIFICADOS POR ISO 27007)

Los hallazgos se clasifican en: NC Mayor (No Conformidad Mayor — compromete la eficacia del SGSI), NC Menor (No Conformidad Menor — incumplimiento puntual sin impacto global) y Observacion (area de mejora sin incumplimiento formal).

ID	Título del hallazgo	Severidad	Clase ISO 27007	Laboratorio de origen	CVSS v3.1
H-01	vsftpd 2.3.4 con backdoor activa (CVE-2011-2523)	CRITICO	NC Mayor	LAB-02 OpenVAS	10.0
H-02	Command Injection explotable sin autenticacion	CRITICO	NC Mayor	LAB-04 DVWA	9.8
H-03	Samba 3.0.20 RCE (CVE-2007-2447) explotable	CRITICO	NC Mayor	LAB-02 OpenVAS	10.0
H-04	SQL Injection en DVWA — exfiltracion completa de BD	CRITICO	NC Mayor	LAB-04 DVWA	9.8
H-05	XSS almacenado persistente en DVWA	ALTO	NC Mayor	LAB-04 DVWA	8.2
H-06	Telnet activo (puerto 23) — credenciales en texto claro	ALTO	NC Mayor	LAB-03 + LAB-05	---
H-07	FTP anonimo activo — datos en texto claro	ALTO	NC Mayor	LAB-03 + LAB-01	---
H-08	Sin politica de contraseñas — contraseñas por defecto	ALTO	NC Mayor	LAB-06 Hydra	---
H-09	Hashes MD5 sin salt en base de datos DVWA	ALTO	NC Mayor	LAB-06 Hashcat	---
H-10	Firewall stateless — vulnerable a evasion ACK/FIN	MEDIO	NC Menor	LAB-05 Nmap	---
H-11	MySQL expuesto en red sin restriccion de origen	ALTO	NC Mayor	LAB-05 + LAB-06	---
H-12	Sistema operativo obsoleto (Ubuntu 8.04, EoL 2013)	MEDIO	NC Menor	LAB-02 OpenVAS	---
H-13	Ausencia de mecanismo de bloqueo de cuenta	MEDIO	NC Menor	LAB-06 Hydra	---
H-14	Ausencia de logging centralizado / SIEM	MEDIO	Observacion	LAB-05	---
H-15	Sin politica de seguridad documentada (ISO 27001 A.5.1)	MEDIO	NC Mayor	LAB-08 Rev. doc.	---

5.1 Fichas de Hallazgo Detalladas

Se incluyen las fichas completas de los 4 hallazgos CRITICOS y los 2 hallazgos ALTOS mas representativos. El alumno debe completar las fichas de los hallazgos restantes.

H-01 vsftpd 2.3.4 con backdoor activa (CVE-2011-2523)	
Severidad	CRITICO
Marco normativo	ENS mp.sw.1 (gestion de parches) - ISO 27001:2022 A.8.8 (gestion de vulnerabilidades tecnicas) - RGPD art. 32

Descripcion del hallazgo	La version 2.3.4 de vsftpd incluye una backdoor introducida maliciosamente en el repositorio oficial. Cuando el nombre de usuario contiene el caracter ':.', vsftpd abre una shell de comandos en el puerto 6200 sin ninguna autentificacion. El exploit esta disponible en Metasploit (exploit/unix/ftp/vsftpd_234_backdoor) y es explotable en menos de 10 segundos. OpenVAS lo detecta con CVSS 10.0 (maximo posible).
Evidencia tecnica	E-03 (OpenVAS, CVSS 10.0, CVE-2011-2523) - E-01 (Nmap, puerto 21/tcp open vsftpd 2.3.4). Evidencia de explotacion disponible en Metasploit Framework (modulo unix/ftp/vsftpd_234_backdoor).
Impacto	Acceso root completo al servidor sin autentificacion. Compromisos total de todos los activos dependientes (SW-01 a SW-06, D-01 a D-03, S-01 a S-06). Si el sistema trata datos personales: brecha notificable a AEPD en 72h (RGPD art. 33). Riesgo MAGERIT: CRITICO (P=5, I=5, R=25).
Recomendacion	ACCION 1: Actualizar vsftpd a version >= 2.3.5 de forma INMEDIATA: apt-get install vsftpd o deshabilitar el servicio si FTP no es imprescindible: systemctl disable vsftpd -now. ACCION 2: Restringir el puerto 21 en iptables a IPs de origen autorizadas. ACCION 3: Implementar proceso formal de gestion de parches (ENS mp.sw.1) para evitar recurrencia.
Plazo de correccion	INMEDIATO — 24 horas como plazo maximo absoluto
Responsable	Administrador de sistemas + Responsable de Seguridad

H-03 Samba 3.0.20 — Ejecucion remota de codigo (CVE-2007-2447)	
Severidad	CRITICO
Marco normativo	ENS mp.sw.1 - ISO 27001:2022 A.8.8 - MAGERIT v3 [A.11]
Descripcion del hallazgo	El servicio Samba de Metasploitable 2 (version 3.0.20) contiene una vulnerabilidad critica de inyeccion de comandos en el modulo usermap_script (CVE-2007-2447, CVSS 10.0). Permite inyectar comandos del SO a traves del nombre de usuario en la autentificacion SMB. No requiere credenciales. El exploit esta disponible en Metasploit (exploit/multi/samba/usermap_script) y proporciona shell root en segundos.
Evidencia tecnica	E-03 (OpenVAS, CVE-2007-2447, CVSS 10.0) - E-01 (Nmap: 139/tcp open netbios-ssn, 445/tcp open microsoft-ds Samba smbd 3.0.20).
Impacto	RCE con privilegios root sin autentificacion previa. Acceso total y persistente al servidor. Mismas consecuencias que H-01 pero a traves de un vector diferente. Dos vulnerabilidades CRITICAS independientes sobre el mismo servidor multiplican el riesgo global.
Recomendacion	Deshabilitar Samba si no es estrictamente necesario: systemctl disable smbd nmbd --now. Si es necesario, actualizar a Samba >= 3.6.3. Verificar que los puertos 139 y 445 estan en DROP en iptables (confirmado en LAB-05, mantener). Auditar periodicamente la lista de servicios activos contra el inventario autorizado.
Plazo de correccion	INMEDIATO — 24 horas
Responsable	Administrador de sistemas

H-04 SQL Injection en DVWA — exfiltracion completa de base de datos	
Severidad	CRITICO
Marco normativo	ENS mp.sw.2 (proteccion de aplicaciones) - ISO 27001:2022 A.8.25 (ciclo de vida seguro) - RGPD art. 25 y 32 - OWASP A03:2021 - WSTG-INPV-05
Descripcion del hallazgo	La aplicacion DVWA es vulnerable a SQL Injection en el parametro 'id' del modulo Brute Force. La inyeccion permite extraer el esquema completo de la base de datos, incluyendo todos los usuarios y sus hashes de contrasena. Ademàs, MySQL esta accesible desde la red (puerto 3306 abierto) con usuario root sin contrasena.

Evidencia tecnica	Combinando SQLi + MySQL sin contrasena, se obtiene acceso completo a todas las bases de datos del servidor. E-07 (Burp Suite Repeater — payloads: 1' OR 1=1-- / UNION SELECT user,password FROM users--) - E-11 (hashes extraidos) - E-12 (Hashcat: 5/5 hashes crackeados en < 30 segundos) - E-03 (OpenVAS: MySQL sin contrasena, CVSS 9.0).
Impacto	Exfiltracion completa de datos de usuarios. Posibilidad de modificar o eliminar datos de la BD (impacto en I). Escalada a MySQL root permite comprometer otras BDs del servidor. Si la BD contiene datos personales: doble obligacion normativa (RGPD art. 32 medidas inadecuadas + art. 33 notificacion de brecha). Sancion potencial art. 83.4 RGPD: hasta 10M EUR o 2% facturacion global.
Recomendacion	SQLi: Implementar prepared statements o consultas parametrizadas en todo el codigo de DVWA. MySQL: Establecer contrasena para root y crear usuarios con minimos privilegios por BD. Hashes: Migrar de MD5 a bcrypt (password_hash PHP, cost >= 12). Puerto 3306: restringir a localhost en iptables.Codigo: revision completa de seguridad de todas las aplicaciones web del servidor.
Plazo de correccion	URGENTE — 72 horas para los tres vectores
Responsable	Desarrollador web + Administrador de BD + Responsable de Seguridad

H-06 Servicio Telnet activo (puerto 23) — credenciales en texto claro	
Severidad	ALTO
Marco normativo	ENS mp.com.2 (cifrado de comunicaciones, INCUMPLIMIENTO DIRECTO) - ISO 27001:2022 A.8.24 (uso de criptografia) - MAGERIT [A.14] - RGPD art. 32.1.a
Descripcion del hallazgo	El servicio Telnet esta activo y accesible desde la red (puerto 23 OPEN, confirmado en LAB-01 y LAB-05). El LAB-03 demostro que la captura de trafico Telnet con Wireshark permite obtener el nombre de usuario y la contrasena en texto claro en tiempo real durante la autentificacion. El firewall (iptables, auditado en LAB-05) tiene una regla ACCEPT explicita para el puerto 23, contradiciendo la politica de denegacion por defecto.
Evidencia tecnica	E-04 (Wireshark: captura_telnet.pcap — credenciales msfadmin:msfadmin en texto claro) - E-10 (iptables: regla -A INPUT -p tcp --dport 23 -j ACCEPT) - E-01 (Nmap: 23/tcp open telnet).
Impacto	Compromisos de credenciales de administracion en cualquier sesion Telnet capturada. Violacion directa del ENS mp.com.2 (cifrado obligatorio de comunicaciones de gestion). Si un atacante en la misma red captura la sesion, obtiene acceso root al servidor. Especialmente critico en redes compartidas (aula, wifi corporativa).
Recomendacion	ACCION 1: Eliminar la regla iptables: iptables -D INPUT -p tcp --dport 23 -j ACCEPT. ACCION 2: Deshabilitar el servicio: systemctl disable telnetd --now. ACCION 3: Configurar y comunicar a todos los administradores el uso exclusivo de SSH para la gestion remota. ACCION 4: Revisar todos los servicios que usen comunicaciones en texto claro (FTP, HTTP para gestion) y sustituirlos por alternativas cifradas.
Plazo de correccion	INMEDIATO — 24 horas (impacto directo en confidencialidad de credenciales)
Responsable	Administrador de sistemas + Responsable de Seguridad

H-08 Ausencia de politica de contrasenas — contrasenas por defecto sin cambiar	
Severidad	ALTO
Marco normativo	ENS op.acc.5 (mecanismo de autentificacion) - ISO 27001:2022 ctrl. 5.17 (informacion de autentificacion) - LOPDGGD art. 5 - NIST SP 800-63B
Descripcion del hallazgo	El sistema no tiene configurada ninguna politica de contrasenas (sin modulos PAM pam_pwquality ni pam_faillock). Las cuentas msfadmin y root conservan las

Evidencia tecnica	contrasenas por defecto de la instalacion (msfadmin:msfadmin, root:toor). El ataque de fuerza bruta con Hydra (LAB-06) obtuvo las credenciales en menos de 10 segundos. No existe mecanismo de bloqueo de cuenta tras intentos fallidos.
	E-13 (Hydra: msfadmin:msfadmin obtenida en < 10s via SSH) - E-14 (cat /etc/pam.d/common-auth: sin pam_faillock) - E-12 (John: root:toor crackeada en modo single). Hydra completo 14.000+ intentos sin ningun bloqueo.
Impacto	Acceso root al sistema en segundos mediante ataque de diccionario basico. Violacion de ENS op.acc.5 (autenticacion insuficiente para categoria BASICA). Si el sistema trata datos personales: las medidas de seguridad son claramente inadecuadas al riesgo (LOPDGDD art. 5 / RGPD art. 32). La ausencia de account lockout multiplica el riesgo de fuerza bruta en todos los servicios.
Recomendacion	ACCION 1: Cambiar inmediatamente contrasenas por defecto: passwd root y passwd msfadmin. ACCION 2: Configurar pam_pwquality en /etc/pam.d/common-password: minlen=12, dcredit=-1, ucredit=-1, lcredit=-1, ocredit=-1. ACCION 3: Configurar pam_faillock: bloqueo tras 5 intentos fallidos, duracion 30 minutos. ACCION 4: Instalar y configurar fail2ban para SSH, FTP y servicios HTTP. ACCION 5: Evaluar implementacion de MFA para acceso SSH (pam_google_authenticator).
Plazo de correccion	INMEDIATO para contrasenas por defecto (24h) — 7 dias para politica PAM completa
Responsable	Administrador de sistemas

Fichas H-02, H-05, H-07, H-09 a H-15 — Completar por el alumno usando la misma estructura:

Campo de la ficha	H-02 Command Injection	H-09 MD5 sin salt	H-13 Sin account lockout
Severidad	CRITICO	ALTO	MEDIO
Marco normativo			
Descripcion del hallazgo			
Evidencia tecnica (ID E-xx)			
Impacto			
Recomendacion			
Plazo			
Responsable			

6. RESUMEN EJECUTIVO

El resumen ejecutivo esta destinado a la direccion y a los responsables de la organizacion. Debe ser comprensible sin conocimientos tecnicos profundos, centrado en el impacto de negocio y las decisiones de inversion de seguridad.

6.1 Vision general de la postura de seguridad

Indicador KPI	Resultado	Nivel
Vulnerabilidades CRITICAS (CVSS >= 9.0)	3 (vsftpd, Samba, PHP CGI)	CRITICO
Hallazgos de auditoria NC Mayor	10 de 15 hallazgos totales	CRITICO
Nivel de riesgo global (MAGERIT v3)	CRITICO — 4 riesgos criticos sin mitigar	CRITICO
Cumplimiento ENS (controles auditados)	2 de 8 controles CONFORMES (25%)	NO CONFORME
Cumplimiento ISO 27001:2022 (Annex A)	Muy bajo — ausencia de controles basicos	NO CONFORME
Confidencialidad de credenciales en red	CRITICA — Telnet y FTP en texto claro	CRITICO
Resistencia al brute force	NULA — sin account lockout en ningun servicio	NO CONFORME
Calidad de hashes de contraseñas	MUY BAJA — MD5 sin salt en aplicaciones web	NO CONFORME
Documentacion de seguridad	INEXISTENTE — 0 de 8 documentos clave	NO CONFORME
Nivel de madurez de seguridad (CMM 1-5)	Nivel 1 (Inicial) — sin procesos formales	CRITICO

6.2 Los tres riesgos mas criticos

1. ACCESO NO AUTORIZADO INMEDIATO (H-01, H-03): Dos vulnerabilidades criticas independientes (vsftpd backdoor y Samba RCE) permiten obtener acceso root al servidor sin autentificacion en menos de 30 segundos. Un atacante con acceso a la red puede comprometer el sistema completamente sin necesidad de ninguna credencial. Este es el riesgo mas urgente de resolver.

2. EXPOSICION DE DATOS (H-04, H-09): La combinacion de SQL Injection en las aplicaciones web y el almacenamiento de contraseñas en MD5 sin salt permiten extraer y crackear todas las credenciales de los usuarios de las aplicaciones. Si el sistema trata datos personales, esto constituye una brecha de seguridad con obligacion de notificacion a la AEPD en 72 horas (RGPD art. 33).

3. COMUNICACIONES SIN CIFRADO (H-06, H-07): Los servicios Telnet y FTP transmiten todas las comunicaciones, incluyendo credenciales, en texto claro. Cualquier dispositivo en la misma red puede capturar estas credenciales con una herramienta basica de analisis de trafico. Esto viola directamente el ENS mp.com.2 (cifrado obligatorio de comunicaciones de gestion).

6.3 Inversion de seguridad recomendada

Fase	Acciones	Coste estimado	Reduccion de riesgo	Plazo
------	----------	----------------	---------------------	-------

		(horas tecnico)		
1 - Urgente	Parchear vsftpd, deshabilitar Samba, cambiar contraseñas root/msfadmin, deshabilitar Telnet	4 horas	Elimina los 3 riesgos CRITICOS	24 horas
2 - Prioritaria	Prepared statements DVWA, bcrypt en aplicaciones, restricción MySQL a localhost	8 horas desarrollo + 2h sysadmin	Elimina riesgos ALTOS de datos	72 horas
3 - Planificada	pam_faillock, fail2ban, pam_pwquality, iptables stateful, documentar políticas	6 horas	Consolida la postura de seguridad	7 días
4 - Estrategica	Plan de gestión de parches, inventario actualizado, política de seguridad, análisis riesgos anual	20 horas + soporte externo	Alcanza cumplimiento ENS básico	30-90 días

Inversión total estimada: 40 horas de trabajo técnico interno (sin coste adicional de personal) + posible soporte externo para la fase estratégica. Esta inversión es marginal comparada con el riesgo de una brecha: el coste medio de un incidente de seguridad en una PYME española supera los 35.000 EUR (INCIBE, 2023), sin contar sanciones RGPD ni daño reputacional.

7. ANALISIS NORMATIVO ESPECIFICO

7.1 Evaluacion de cumplimiento ENS

Para los efectos de este laboratorio, se asume que Metasploitable 2 es un sistema de categoria BASICA del ENS. Los controles del Anexo II del ENS aplicables a esta categoria se evaluan a continuacion:

Control ENS	Descripcion del control	Estado	Evidencia	Hallazgo
org.1	Politica de seguridad de la informacion	NO CONFORME	E-16 (Rev. documental)	H-15: Ausencia total de politica documentada
op.pl.1	Analisis de riesgos	NO CONFORME	E-16	No existia antes de esta auditoria
op.acc.1	Identificacion y control de acceso	NO CONFORME	E-13, E-14	Sin politica de contraseñas ni control de acceso
op.acc.5	Mecanismo de autenticacion	NO CONFORME	E-13, E-14	Contraseñas por defecto, sin MFA, sin lockout
op.exp.1	Inventario de activos	NO CONFORME	E-16	No existia antes de esta auditoria
op.exp.4	Gestion de parches	NO CONFORME	E-03	Sistema sin parchear desde 2008
op.mon.1	Deteccion de intrusiones	NO CONFORME	E-10	Sin IDS/IPS ni alertas configuradas
mp.com.1	Perimetro seguro	PARCIAL	E-10	Firewall presente pero stateless y con reglas incorrectas
mp.com.2	Cifrado de comunicaciones	NO CONFORME	E-04, E-05	Telnet y FTP activos — texto claro
mp.si.2	Cifrado de informacion	PARCIAL	E-11, E-12	SHA-512 en shadow (correcto) / MD5 en MySQL (incorrecto)
mp.sw.1	Gestion de actualizaciones SW	NO CONFORME	E-03	vsftpd 2.3.4, Samba 3.0.20, PHP CGI: todos con CVEs criticos
mp.sw.2	Proteccion de aplicaciones web	NO CONFORME	E-07, E-08, E-09	SQLi, XSS, CMDi explotables en DVWA

Resultado ENS: 1 control PARCIAL (mp.com.1 y mp.si.2 con conformidad parcial), 10 controles NO CONFORMES. El sistema no alcanza el nivel BASICA del ENS en ninguna de las categorias auditadas. No estaria habilitado para operar como sistema de una AA.PP.

7.2 Evaluacion de cumplimiento ISO 27001:2022 (controles relevantes)

Control ISO 27001:2022	Descripcion	Estado	Evidencia	Observacion
A.5.1	Políticas de seguridad de la informacion	NO CONFORME	E-16	Ausencia total — NC Mayor
A.5.9	Inventario de activos	NO CONFORME	E-16	Generado por el auditor, no existia previo
A.5.17	Informacion de autenticacion	NO CONFORME	E-13, E-14	Contraseñas por defecto, MD5, sin lockout — NC Mayor

A.8.5	Autenticacion segura	NO CONFORME	E-13	Sin MFA, sin lockout — NC Mayor
A.8.8	Gestion de vulnerabilidades tecnicas	NO CONFORME	E-03	Sin proceso de parches — NC Mayor
A.8.20	Seguridad de redes	PARCIAL	E-10	Firewall presente pero misconfigured
A.8.22	Segregacion de redes	NO CONFORME	E-01, E-10	Sin segmentacion — todos los servicios en la misma red
A.8.24	Uso de criptografia	NO CONFORME	E-04, E-05	Telnet, FTP, MD5 — NC Mayor
A.8.25	Ciclo de vida seguro del desarrollo	NO CONFORME	E-07, E-08	SQLi, XSS en produccion — NC Mayor
A.8.29	Pruebas de seguridad en desarrollo	NO CONFORME	E-16	Sin proceso de pruebas de seguridad documentado

7.3 Evaluacion RGPD — impacto en proteccion de datos

Si Metasploitable 2 tratara datos personales reales (es un entorno de laboratorio, pero el analisis normativo aplica como si fuera real):

Articulo RGPD	Requisito	Estado	Consecuencia del incumplimiento
Art. 25	Privacidad desde el diseno	NO CONFORME	Las aplicaciones web no integran seguridad desde el diseno (SQLi, XSS en produccion)
Art. 32.1.a	Seudonimizacion y cifrado de datos	NO CONFORME	Contraseñas en MD5 sin salt, comunicaciones sin cifrar (Telnet, FTP)
Art. 32.1.b	Confidencialidad e integridad permanentes	NO CONFORME	Vulnerabilidades criticas sin mitigar comprometen confidencialidad e integridad
Art. 32.1.d	Proceso de verificacion periodica	NO CONFORME	No existia ningun proceso de auditoria previo a este laboratorio
Art. 33	Notificacion de brecha en 72h	APLICA	Si cualquiera de los hallazgos CRITICOS hubiera sido explotado: obligacion de notificacion a AEPD
Art. 35	DPIA obligatoria	EVALUAR	Depende del tipo de datos tratados. Si es tratamiento de alto riesgo: DPIA obligatoria previa
Art. 83.4	Sancion por incumplimiento del art. 32	RIESGO	Hasta 10.000.000 EUR o 2% de la facturacion anual global (lo que sea mayor)

8. DECLARACION DE APLICABILIDAD ENS — GAP ANALYSIS

La Declaracion de Aplicabilidad (DA) es el documento que lista todos los controles de seguridad aplicables al sistema, indica si estan implementados, justifica las exclusiones y define las acciones de mejora. Es obligatoria para la certificacion ISO 27001 y recomendada para la conformidad ENS.

Control ENS	Aplicable?	Estado actual	Riesgo asociado	Accion requerida	Ref. PTR
org.1 Politica seguridad	SI	NO CONFORME	H-15	Redactar politica de seguridad (doc. formal)	Fase 4
op.pl.1 Analisis riesgos	SI	NO CONFORME	R-01 a R-10	Realizar analisis de riesgos anual — iniciado en LAB-07	Fase 4
op.acc.1 Control acceso	SI	NO CONFORME	H-08	Implementar IAM basico, revision de cuentas	Fase 3
op.acc.5 Autenticacion	SI	NO CONFORME	H-08, H-13	pam_faillock + pam_pwquality + MFA SSH	Fase 3
op.exp.1 Inventario	SI	NO CONFORME	Todos	Mantener inventario actualizado — iniciado en LAB-01	Fase 4
op.exp.4 Parches	SI	NO CONFORME	H-01, H-03, H-12	Plan de gestion de parches mensual	Fase 1+4
op.mon.1 Deteccion	SI	NO CONFORME	H-14	fail2ban + alertas de log + SIEM basico	Fase 3
mp.com.1 Perimetro	SI	PARCIAL	H-10, H-11	iptables stateful + restricción MySQL	Fase 3
mp.com.2 Cifrado comun.	SI	NO CONFORME	H-06, H-07	Deshabilitar Telnet/FTP — usar SSH/SFTP	Fase 1
mp.si.2 Cifrado info	SI	PARCIAL	H-09	MD5->bcrypt en aplicaciones web	Fase 2
mp.sw.1 Parches SW	SI	NO CONFORME	H-01, H-03	Actualizar vsftpd, Samba, PHP, sistema	Fase 1
mp.sw.2 Protec. web	SI	NO CONFORME	H-02, H-04, H-05	Prepared statements, output encoding, CSP	Fase 2
mp.per.1 Formacion	SI	NO CONFORME	H-08, H-15	Plan de formacion en seguridad para administradores	Fase 4

9. PLAN DE ACCION Y SEGUIMIENTO

El Plan de Accion es el compromiso formal de la organizacion para corregir las no conformidades identificadas. Cada medida tiene un responsable, un plazo y un KPI de verificacion que el auditor usara en la auditoria de seguimiento para verificar el cierre de los hallazgos.

Ref. H.	NC	Medida correctora	Responsable	Plazo	KPI de verificacion	Coste estimado
H-01	Mayor	Actualizar vsftpd >= 2.3.5 o deshabilitar	Sysadmin	24h	nmap -sV: version >= 2.3.5 o puerto 21 cerrado	0 EUR
H-03	Mayor	Deshabilitar Samba: systemctl disable smbd	Sysadmin	24h	nmap: puertos 139/445 CLOSED o FILTERED	0 EUR
H-06	Mayor	Eliminar Telnet de iptables + systemctl disable	Sysadmin	24h	nmap: puerto 23 CLOSED / nmap -sS -p 23 -> closed	0 EUR
H-08	Mayor	passwd root/msfadmin + pam_pwquality + pam_faillock	Sysadmin	24h-7d	hydra: sin credenciales por defecto; pam config verificado	0 EUR
H-02	Mayor	Implementar input validation + output encoding en DVWA	Dev	72h	sqlmap sin resultados en los endpoints corregidos	8h dev
H-04	Mayor	Prepared statements + restriccion MySQL a localhost	Dev+Sysadmin	72h	sqlmap sin extraccion; nmap: 3306 FILTERED	8h dev + 1h sys
H-09	Mayor	Migrar hashes MD5 a bcrypt en aplicaciones web	Dev	72h	hash-identifer: \$2y\$ en todos los hashes de BD	6h dev
H-05	Mayor	Implementar CSP, output encoding, HttpOnly cookies	Dev	72h	OWASP ZAP: sin alertas XSS en endpoints corregidos	4h dev
H-07	Mayor	Deshabilitar FTP anonimo; migrar a SFTP	Sysadmin	48h	nmap: sin FTP anonimo; configurar vsftpd.conf	0 EUR
H-10	Menor	Agregar conntrack a iptables; migrar a nftables	Sysadmin	7 dias	nmap -sA: FILTERED en puertos protegidos	0 EUR
H-11	Mayor	iptables: -A INPUT -p tcp -s 127.0.0.1 --dport 3306 -j ACCEPT	Sysadmin	24h	nmap: 3306 FILTERED desde cualquier IP excepto localhost	0 EUR
H-12	Menor	Planificar migracion a SO soportado (Ubuntu 22.04 LTS)	CTO/Sysadmin	90 dias	Version OS: cat /etc/os-release	Coste proyecto
H-13	Menor	pam_faillock: deny=5, unlock_time=1800	Sysadmin	7 dias	hydra: bloqueo tras 5 intentos verificado	0 EUR
H-14	Obs.	Instalar fail2ban + configurar alertas /var/log	Sysadmin	7 dias	fail2ban --status; alertas activas en /etc/fail2ban	0 EUR
H-15	Mayor	Redactar politica de seguridad de la informacion	CISO/Dir.	30 dias	Documento firmado y publicado internamente	4h redaccion

9.1 Seguimiento y auditoria de cierre

ISO 27007 exige que el auditor realice una auditoria de seguimiento para verificar que las acciones correctoras se han implementado y son eficaces. Se establece el siguiente calendario de verificacion:

Hito de seguimiento	Plazo	Alcance	Metodo de verificacion
Verificacion Fase 1 (urgente)	72 horas	H-01, H-03, H-06, H-08 (contrasenas), H-11	Nmap + Hydra + verificacion SSH manual
Verificacion Fase 2 (datos)	1 semana	H-02, H-04, H-05, H-07, H-09	sqlmap + OWASP ZAP + hash-identifier en BD
Verificacion Fase 3 (perimetro)	2 semanas	H-10, H-13, H-14	Nmap -sA + hydra bloqueo + fail2ban status
Auditoria de cierre completa	3 meses	Todos los hallazgos + nueva revision documental	Auditoria completa segun ISO 27007
Auditoria periodica ENS	Cada 2 anos	Sistema completo segun Anexo II ENS categoria auditada	Auditoria formal ENS (art. 31 RD 311/2022)

10. CONTROL DE VERSIONES, FIRMAS Y DISTRIBUCION

10.1 Control de versiones del informe

Version	Fecha	Autor	Cambios	Estado
0.1	___/___/___	Alumno: _____	Borrador inicial — hallazgos principales	Borrador
0.2	___/___/___	Alumno: _____	Incorporacion hallazgos normativos y plan de accion	Revision interna
1.0	___/___/___	Alumno: _____	Version final aprobada tras revision del instructor	FINAL

10.2 Firmas y aprobaciones

Rol	Nombre	Firma	Fecha	Funcion en la auditoria
Auditor principal	_____	_____	___/___/___	Responsable de la ejecucion y del informe
Instructor / Revisor	_____	_____	___/___/___	Revision tecnica y normativa del informe
Responsable del sistema	Metasploitable 2 (Lab)	N/A — entorno de lab	___/___/___	Receptor del informe
Coordinador del curso	_____	_____	___/___/___	Aprobacion final del informe de laboratorio

10.3 Lista de distribucion

Destinatario	Cargo	Formato	Nivel de acceso	Fecha de envio
Alumno	Auditor del laboratorio	PDF + DOCX	Completo	___/___/___
Instructor	Evaluador del laboratorio	PDF	Completo	___/___/___
Coordinador MF0487_3	Coordinador del modulo	PDF	Resumen ejecutivo	___/___/___

11. ENTREGABLE FINAL — ESTRUCTURA DEL INFORME COMPLETO

El Informe de Auditoria de Seguridad final debe ser un documento unico y coherente que integre todos los resultados de los ocho laboratorios. Estructura minima exigida:

11.1 Indice del informe final

1. Portada con clasificacion CONFIDENCIAL, datos del proyecto y control de versiones.
2. Indice de contenidos con numeracion de paginas.
3. Indice de tablas, figuras y evidencias.
4. Resumen ejecutivo (maximo 2 paginas, sin tecnicismos — seccion 6 de este documento).
5. 1. Plan de auditoria: alcance, objetivos, metodologia, equipo (seccion 2).
6. 2. Revision documental: documentacion existente y gaps (seccion 3).
7. 3. Evidencias tecnicas: registro completo con ID, herramienta y fichero adjunto (seccion 4).
8. 4. Hallazgos de la auditoria: tabla resumen + fichas completas H-01 a H-15 (seccion 5).
9. 5. Analisis normativo: ENS, ISO 27001, RGPD (seccion 7).
10. 6. Declaracion de aplicabilidad y gap analysis ENS (seccion 8).
11. 7. Plan de accion con KPIs y calendario de seguimiento (seccion 9).
12. 8. Control de versiones, firmas y distribucion (seccion 10).
13. 9. Anexos: todos los ficheros de evidencia enumerados en E-01 a E-16.

11.2 Ficheros a entregar

Fichero	Descripcion	Origen
informe_auditoria_final.pdf	Informe completo (este documento completado)	LAB-08
resumen_ejecutivo.pdf	Resumen ejecutivo independiente (2 paginas)	LAB-08 seccion 6
declaracion_aplicabilidad.xlsx	DA completa con todos los controles ENS	LAB-08 seccion 8
plan_accion.xlsx	Plan de accion con seguimiento	LAB-08 seccion 9
E-01 nmap_syn_full.txt	Mapa completo de puertos	LAB-01
E-02 inventario_activos.xml	Inventario Nmap en XML	LAB-01
E-03 openvas_report.xml	Informe completo OpenVAS	LAB-02
E-04 captura_telnet.pcap	Captura credenciales Telnet	LAB-03
E-05 captura_ftp.pcap	Captura credenciales FTP	LAB-03
E-07 burp_sqlmap_repeater.png	Captura Burp SQLi	LAB-04
E-10 iptables_actual.txt	Volcado ruleset iptables	LAB-05
E-12 hashcat_md5.txt	Resultado crackeo hashes DVWA	LAB-06
E-13 hydra_ssh.txt	Resultado Hydra SSH	LAB-06
E-15 registro_riesgos.xlsx	Registro completo de riesgos	LAB-07

12. PREGUNTAS DE REFLEXION FINAL

- * El art. 31 del ENS establece que los sistemas de categoria MEDIA y ALTA deben auditarse cada dos anos por 'personal cualificado e independiente'. Discute: que implicaciones tiene el requisito de independencia del auditor? Podria el mismo equipo de sistemas que administra el servidor auditado realizar la auditoria? Por que la independencia es un principio fundamental en ISO 27007? Como se certifica la cualificacion de un auditor de seguridad en Espana?
- * Has identificado 10 NC Mayores en este laboratorio. ISO 27007 clasifica los hallazgos en NC Mayor, NC Menor y Observacion. Justifica por que H-08 (ausencia de politica de contraseñas) es NC Mayor y no NC Menor: que criterio de la norma determina esta clasificacion? Si el responsable del sistema argumentara que la politica de contraseñas es 'informal y conocida por todos', como rebatirias este argumento desde la perspectiva de ISO 27007 y el ENS?
- * El RGPD art. 83 establece sanciones de hasta 10 millones de EUR o 2% de la facturacion global por incumplimiento del art. 32. Aplica el analisis de coste-beneficio: si una empresa con 5 millones de EUR de facturacion tiene un sistema con los hallazgos de este laboratorio y sufre una brecha, cual seria la sancion maxima posible? Cuanto ha costado el plan de accion (seccion 9)? Calcula el ROI de la inversion de seguridad.
- * La LOPDGDD Disposicion adicional primera establece que las medidas de seguridad del ENS son el marco de referencia para las AA.PP. en su cumplimiento del RGPD art. 32. Un ayuntamiento espanol tiene un servidor con estos mismos hallazgos. Ademas de las sanciones RGPD, que responsabilidades especificas tendria segun la LOPDGDD y el ENS? Quien seria el responsable juridicamente: el alcalde, el concejal de informatica, el administrador de sistemas, o el DPO?
- * Este es el octavo y ultimo laboratorio del curso. Reflexiona sobre el proceso completo de auditoria: desde el reconocimiento inicial (LAB-01) hasta el informe final (LAB-08). Identifica cual fue el hallazgo que mas te sorprendio y por que. Que tecnica de los laboratorios consideras mas util en una auditoria real? Si tuvieras que auditar un sistema de una empresa real manana, que pasos seguirias y que documentacion generarias antes de empezar?

13. RUBRICA DE EVALUACION

Criterio	Insuficiente (0-4)	Suficiente (5-7)	Excelente (8-10)
Estructura e integracion del informe (25%)	Informe incompleto o sin estructura ISO 27007	Estructura basica con secciones principales	Informe completo siguiendo ISO 27007 con todas las secciones, control de versiones y firmas
Calidad y trazabilidad de los hallazgos (30%)	Hallazgos sin evidencia o sin referencia normativa	Hallazgos con evidencia y referencia basica	Todos los hallazgos con evidencia numerada, CVSS, referencia normativa cruzada y trazabilidad a los labs
Analisis normativo ENS / LOPDGDD / ISO 27007 (25%)	Sin analisis normativo o solo menciones superficiales	Referencia a los controles principales con conformidad indicada	Declaracion de aplicabilidad completa con conformidad, gap analysis y justificacion de exclusiones
Calidad del plan de accion y resumen ejecutivo (20%)	Sin plan de accion o resumen ejecutivo inadecuado	Plan de accion con medidas basicas y plazo	Plan de accion priorizado con responsables, plazos, costes y KPIs de seguimiento; resumen ejecutivo de calidad directiva

Nota final del laboratorio: media ponderada de los cuatro criterios. Nota minima de 5 en cada criterio para aprobar.

Nota final del curso (MF0487_3): media ponderada de los ocho laboratorios. Los laboratorios 7 y 8 tienen peso doble por ser los laboratorios de sintesis.

i El Informe de Auditoria de Seguridad completado en este laboratorio es el documento que, en un proyecto real, el cliente recibe, firma y usa para tomar decisiones de inversion de seguridad. Su calidad refleja directamente la competencia profesional del auditor. En el mercado laboral, la capacidad de producir informes de calidad directiva (no solo tecnicos) es uno de los diferenciadores mas valorados en perfiles de auditoria y ciberseguridad.

14. REFERENCIAS

Normas de auditoria

- * ISO/IEC 27007:2011 — Guidelines for Information Security Management Systems Auditing. ISO, Geneva, 2011.
- * ISO/IEC 19011:2018 — Guidelines for Auditing Management Systems. ISO, Geneva, 2018.
- * ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection — ISMS Requirements. ISO, 2022.
- * ISO/IEC 27002:2022 — Information Security Controls. ISO, 2022.

Normativa española

- * Real Decreto 311/2022 de 3 de mayo — Esquema Nacional de Seguridad. Arts. 13, 31, Anexo II. BOE num. 106, 2022.
- * Ley Organica 3/2018 de 5 de diciembre — Proteccion de Datos Personales y Garantia de los Derechos Digitales (LOPDGDD). Arts. 5, 28. BOE num. 294, 2018.
- * Reglamento (UE) 2016/679 del Parlamento Europeo — RGPD. Arts. 25, 32, 33, 34, 35, 83. DOUE, 2016.

Guías CCN y metodologías

- * CCN-CERT. CCN-STIC 802 — Auditoria del Esquema Nacional de Seguridad. Centro Criptologico Nacional.
- * CCN-CERT. CCN-STIC 803 — Valoracion de sistemas en el ENS. Centro Criptologico Nacional.
- * CCN-CERT. CCN-STIC 804 — Guia de implantacion del ENS. Centro Criptologico Nacional.
- * CCN-CERT. MAGERIT v3 — Metodologia de Analisis y Gestion de Riesgos. Libros I, II y III. MINHAP, 2012.
- * NIST. SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments. NIST, 2012.

Estandares tecnicos de referencia

- * OWASP Foundation. Web Security Testing Guide v4.2. <https://owasp.org/www-project-web-security-testing-guide/>
- * OWASP Foundation. OWASP Top 10:2021. <https://owasp.org/Top10/>
- * FIRST.org. Common Vulnerability Scoring System v3.1 Specification. <https://www.first.org/cvss/>
- * ISECOM. OSSTMM v3 — Open Source Security Testing Methodology Manual. ISECOM, 2010.
- * AEPD. Guia para el analisis de riesgo en el tratamiento de datos personales. Madrid: AEPD, 2021.
- * AEPD. Guia de la Evaluacion de Impacto en la Proteccion de Datos (EIPD). Madrid: AEPD, 2021.